

Análise e Desenvolvimento de Sistemas

Métricas e Auditoria de Software

Sprint 4 - Aplicação Prática

[G1] Introdução à Auditoria de Sistemas

Grupo: G1

Data de entrega: 08/06/2026

1. Introdução e Contextualização do Estudo de Caso

O presente documento constitui o artefato prático da Sprint 4 para a disciplina de Métricas e Auditoria de Software. Com base nos fundamentos teóricos estabelecidos na etapa anterior, este trabalho apresenta um estudo de caso hipotético detalhado aplicado à empresa **Nexus FinTech S.A.**, uma instituição financeira de médio porte que lida com operações de crédito e custódia de ativos digitais. A organização utiliza um sistema ERP centralizado (denominado CoreFin) para gerenciar o fluxo de caixa, balanços, contas a pagar/receber e dados cadastrais de clientes.

Considerando o cenário de alta criticidade e a necessidade de aderência estrita a normas de segurança e governança, foi executada uma simulação de auditoria de sistemas de ponta a ponta focada no módulo financeiro e nos processos de gerenciamento de identidades e acessos (IAM).

2. Escopo Definido

O escopo desta auditoria foi rigorosamente delimitado para avaliar a robustez dos controles lógicos e operacionais do sistema CoreFin no período compreendido entre 01 de janeiro de 2026 e 31 de maio de 2026. A avaliação concentrou-se nos seguintes subdomínios técnicos:

- **Gestão do Ciclo de Vida de Identidades:** Processos de concessão, alteração e revogação de credenciais de acesso ao módulo financeiro do ERP.
- **Segregação de Funções (SoD - Segregation of Duties):** Análise de perfis acumulados que pudessem gerar conflitos de interesse (ex: usuários com permissão simultânea para

criar e aprovar ordens de pagamento).

- **Pistas e Trilhas de Auditoria (Logs):** Verificação da integridade, retenção e proteção dos registros de transações críticas contra modificações não autorizadas.

Exclusões do Escopo: Avaliações físicas de data centers, testes de invasão de rede externa (PenTests) e auditorias de balanços contábeis consolidados não fizeram parte desta iteração.

3. Objetivos da Auditoria

Objetivo Geral: Avaliar a eficácia e a conformidade dos controles internos de TI associados ao sistema ERP CoreFin da Nexus FinTech S.A., mitigando riscos de fraudes financeiras, vazamento de informações e acessos indevidos.

Objetivos Específicos:

- Validar se o desligamento de colaboradores resulta na revogação imediata de seus privilégios de acesso aos sistemas corporativos.
- Mapear a matriz de permissões para identificar desvios nos princípios de privilégio mínimo e segregação de funções.
- Assegurar a existência de logs detalhados para todas as movimentações financeiras de alto valor e confirmar que tais logs não são passíveis de alteração pelos administradores do sistema.

4. Metodologia Utilizada

A metodologia adotada seguiu as diretrizes internacionais estabelecidas pelo framework **COBIT 2019** (objetivos de gerenciamento de identidades e segurança) e os requisitos de controle de acesso da norma **ISO/IEC 27001:2022**. O processo foi estruturado em quatro fases sequenciais:

Fase do Processo	Atividades Práticas Executadas	Técnicas de Auditoria Aplicadas
Fase 1: Planejamento	Definição de cronograma, requisição de políticas internas de segurança e mapeamento inicial da arquitetura do CoreFin.	Análise documental e reuniões de alinhamento com a governança.

Fase do Processo	Atividades Práticas Executadas	Técnicas de Auditoria Aplicadas
Fase 2: Trabalho de Campo	Extração de relatórios de usuários ativos, cruzamento de dados com a base ativa do RH e inspeção de configurações de logs.	Confronto de dados (Data Matching), amostragem estatística e entrevistas técnicas.
Fase 3: Avaliação e Análise	Identificação de vulnerabilidades operacionais e classificação de riscos com base na matriz de impacto e probabilidade.	Análise de causa raiz e mapeamento de lacunas (Gap Analysis).
Fase 4: Relatório e Fechamento	Consolidação dos achados de auditoria e formulação de recomendações preventivas e corretivas para a diretoria.	Redação técnica de relatório e reunião de encerramento (Debriefing).

Tabela 1: Matriz metodológica aplicada ao processo de auditoria de ponta a ponta.

5. Achados de Auditoria e Evidências Técnicas

Durante a fase de execução, a equipe de auditoria identificou não conformidades críticas em relação às políticas internas de segurança e às melhores práticas de governança de TI. Os principais achados estão detalhados a seguir:

ID	Descrição do Achado de Auditoria	Evidência Coletada	Classificação de Risco
ACH-01	Usuários desligados da organização permaneciam com contas ativas no módulo financeiro do ERP CoreFin.	Cruzamento entre a lista de rescisões contratuais fornecida pelo RH e o relatório de usuários ativos emitido pelo banco	Alto

ID	Descrição do Achado de Auditoria	Evidência Coletada	Classificação de Risco
		de dados do ERP indicou que 4 ex-colaboradores mantinham acessos habilitados.	
ACH-02	Ausência de Segregação de Funções (SoD). Dois analistas seniores possuíam permissão simultânea de escrita e homologação na mesma cadeia de pagamento.	Matriz de controle de privilégios configurada no Active Directory (AD) corporativo mapeada diretamente para o perfil 'Finance_Admin'.	Médio
ACH-03	Os registros de log de alterações manuais em tabelas de saldo eram armazenados localmente e podiam ser desativados temporariamente por usuários com perfil 'DBA'.	Arquivo de configuração de Auditoria do SGDB ('sys_audit_config.conf') apresentava parâmetros que permitiam a suspensão da geração de trilhas por administradores de banco de dados.	Alto

Tabela 2: Relatório consolidado de achados de auditoria e criticidade.

6. Recomendações e Plano de Ação

Para sanar as fragilidades apontadas e elevar o nível de maturidade dos controles internos da Nexus FinTech S.A., são estabelecidas as seguintes recomendações mandatórias:

- **Automatização do Offboarding (Para ACH-01):** Implementar uma integração em tempo

real via API entre o sistema de gestão de Recursos Humanos e a ferramenta de IAM corporativa, garantindo o bloqueio automatizado de credenciais em até duas horas após a formalização do desligamento do funcionário.

- **Revisão da Matriz de Perfis (Para ACH-02):** Reestruturar os papéis lógicos dentro do ERP, dividindo o perfil 'Finance_Admin' em duas funções mutuamente exclusivas: 'Finance_Requester' (lançamento) e 'Finance_Approver' (aprovação).
- **Centralização e Proteção de Logs (Para ACH-03):** Configurar o redirecionamento contínuo e imutável de todas as trilhas de auditoria do banco de dados para um servidor SIEM (Security Information and Event Management) externo, com acesso restrito e proibição de exclusão de registros sob o conceito de gravação única e leitura múltipla (WORM).

7. Conclusões

A execução desta auditoria prática de sistemas de ponta a ponta evidenciou que, embora a Nexus FinTech S.A. possua ferramentas tecnológicas avançadas, existem falhas operacionais significativas em seus processos de controle interno. A persistência de credenciais ativas de ex-funcionários e a falta de segregação de funções expõem a instituição a riscos financeiros e de conformidade reputacional graves.

Conclui-se que o papel da auditoria de sistemas transcende a mera identificação de erros cotidianos; ela atua como um pilar essencial para a segurança corporativa de longo prazo. A rápida execução do plano de ação proposto garantirá que a organização alinhe suas práticas de TI aos padrões de governança exigidos pelo mercado atual.

Referências

ABNT NBR ISO/IEC 27001:2022 – Tecnologia da informação – Técnicas de segurança – Sistemas de gestão de segurança da informação - Requisitos.

ISACA. COBIT 2019 Framework: Governance and Management Objectives. ISACA, 2019.

Moraes, G. L. Auditoria de Sistemas de Informação e Governança de TI. 2. ed. São Paulo: Editora Atlas, 2021.